CHAPTER 4

RESEARCH METHODOLOGY AND SOLUTION OVERVIEW

4.1 Introduction

Chapter 3 stated the research gap, the main research question, the six sub-research questions and the six research objectives. This chapter explains how the research was carried out and gives an overview of the solution before the detailed chapters. Section 4.2 defines the terms that the solution uses and that Chapter 3 did not define. Section 4.3 presents the selected research methodology, Design Science Research, and shows what each of its stages produced in this thesis. Section 4.4 gives an overview of the solution as one end-to-end workflow, from the creation of a consent to the recording of an access decision. Sections 4.5 to 4.10 give an overview of the solution for each research question, RQ1 to RQ6, and name the chapter in which each solution is presented in full. Section 4.11 concludes the chapter.

4.2 Key Definitions

The following terms are used in the overview of the solution and in the chapters that follow. The patient, the guardian set G, the threshold N, the authorised doctor D, the access request R and the consent object C were defined in Chapter 3.

Trust predicate. A condition that must hold before access is allowed, evaluated as true or false at the time of the request. The framework has five: VI for identity and authority, VA for collective authorisation, VP for policy and context, VT for temporal validity and VL for the lifecycle state.

Decision function. The rule Decision(C, R, t) that returns ALLOW only when all five trust predicates hold for the consent C, the request R and the time t, and DENY otherwise. It was stated as Equation (3.2).

Approval. A signed statement by one guardian that approves one consent. An approval is valid only when it is signed by a member of G who has not already approved the same consent.

Verified approving set Av. The subset of G whose approvals have been verified. The consent becomes active when |Av| reaches N.

Lifecycle state. The state of a consent at a point in time: pending until the guardians have approved, not started before its start time, active while it can release data, and expired or revoked when it no longer can.

Audit event. A record written to the audit ledger for every action on a consent, including its creation, each approval, each access decision with the result of the five predicates, and its revocation.

Scenario. One complete run of the prototype that exercises a defined path, such as the creation and approval of a consent followed by an allowed request, or a request made after revocation.

Attack scenario. A deliberate attempt to obtain access while one of the trust conditions is not satisfied, such as an approval from a signer outside G or a request outside the authorised data scope. The framework must refuse every attack scenario.

Prototype. The HALAH implementation of the framework, used to show that the design can be built and to evaluate it against the scenarios and attack scenarios.

4.3 Selected Research Methodology

This research follows the Design Science Research (DSR) methodology, based on the process model of Peffers et al. (2007), as shown in Figure 4.1. DSR fits this research because its aim is to design and evaluate an artefact, the trust-oriented authorisation framework and its HALAH prototype, that addresses an identified problem. The process has five stages. Knowledge gained in each stage feeds back into the process through iteration, so that the design is refined over successive cycles.

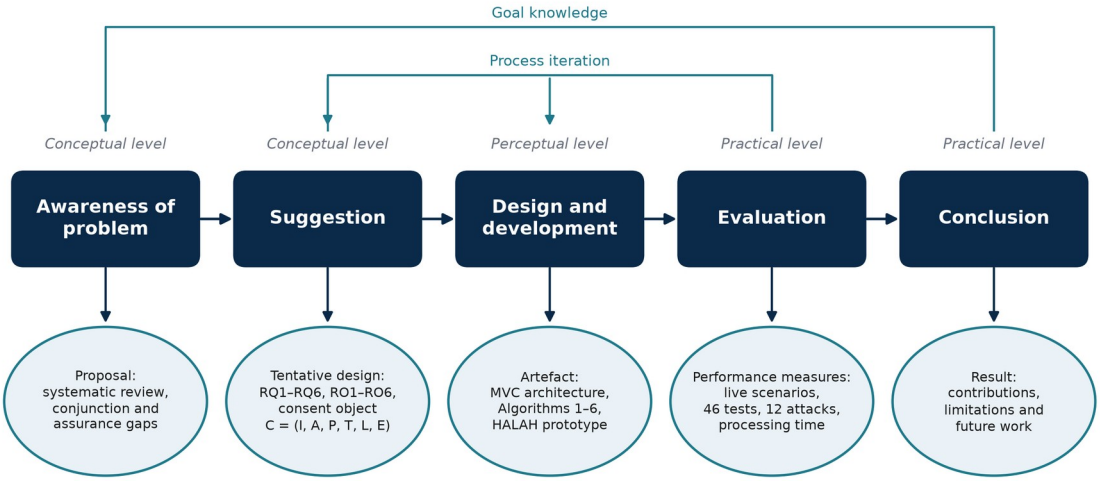


Figure 4.1: The Design Science Research process of this thesis, with the output of each stage, adapted from Peffers et al. (2007).

In the awareness-of-problem stage, the systematic literature review of Chapter 2 identified the fragmentation of trust conditions in existing consent mechanisms, and its output is the research proposal. In the suggestion stage, the research gap was turned into the research questions RQ1 to RQ6, the research objectives RO1 to RO6, and the integrated trust model, which together form the tentative design. In the design and development stage, the consent object C, the MVC architecture, and Algorithms 1 to 6 were designed, and the HALAH artefact was implemented on the Sepolia testnet (Chapters 5 to 10). In the evaluation stage, the artefact was evaluated through access scenarios, 46 automated tests including twelve attack scenarios, and measurements of gas and processing time, which provide the performance measures (Chapter 10). In the conclusion stage, the results, the contributions, and the remaining lifecycle and assurance work are reported.

4.4 Solution Overview

The framework is best understood as one workflow that starts when a patient creates a consent and ends when an access decision is recorded. This section presents that

workflow and the two conditions that govern the collective authorisation step. The architecture that carries the workflow is presented in Chapter 5.

Figure 4.2 presents the end-to-end workflow of the proposed framework. The workflow begins when the patient creates a consent request. The consent specification defines the intended purpose, permitted data scope, and other authorisation conditions. This step establishes what the patient intends to authorise and provides the policy context against which subsequent access requests can be evaluated. The next step of the workflow applies a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The framework separates identity authentication from authorisation. A successfully verified DID or VC does not, by itself, grant permission to access patient data. The framework then collects the participants' independent approvals and evaluates whether the predefined authorisation threshold has been satisfied. Let A_v denote the set of participants whose approvals have been verified and let N denote the required authorisation threshold, as in Equation (4.1). Here, Token(C) $\neq \emptyset$ means that C has been assigned a token identifier, and Revoked(C) $= 0$ means that the consent has not been revoked.

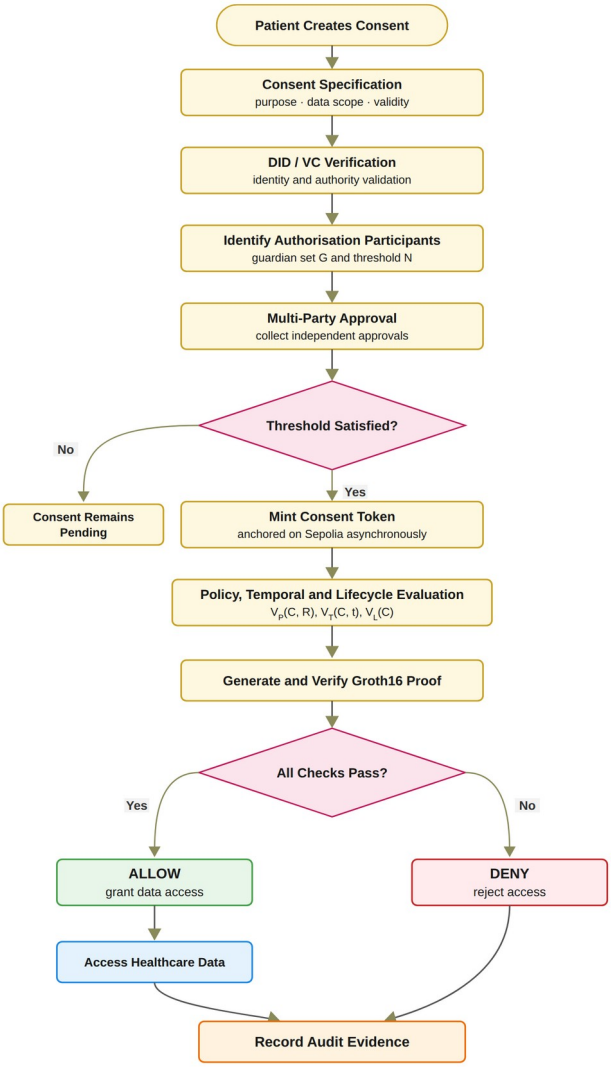


Figure 4.2: End-to-end workflow of the trust-oriented consent authorisation framework.

$$V_A(C) = 1 \text{ if } |A_v| \geq N \wedge \text{Token}(C) \neq \varnothing \wedge \text{Revoked}(C) = 0, \text{ and } 0 \text{ otherwise.} \tag{4.1}$$

Only independently verified participants can contribute to the set of verified approving participants A_v, as defined in Equation (4.2), where A_s denotes the set of approvals submitted for C. A_v therefore contains each member of G at most once, and an approval from a signer outside G does not enter A_v. Consequently, an arbitrary number of unverified or unauthorised approvals cannot satisfy the multi-party authorisation requirement. A compromised or unauthorised participant cannot independently activate access when the threshold has not been satisfied. This distinguishes the framework from reviewed systems in which joint approval is a contingency path, a witness or notary threshold, a registration-time co-consent, a documentation-time gate on guardian access, an institution-side admission gate, a custodial M-of-N signature, a key-share reconstruction, or a threshold proxy re-encryption.

$$A_v = \{g \in G \mid \exists\, a_i \in A_s \text{ submitted by } g \text{ with } V_I(g) = 1\}. \tag{4.2}$$

In the implemented prototype, the threshold is fixed at $N = |G|$, as justified in Chapter 7, and once the N-of-N condition is satisfied, the consent token is minted in the local ledger and a background job anchors the mint on Sepolia asynchronously. The policy, temporal and lifecycle checks V_P, V_T and V_L, together with the exploratory jurisdiction check V_J, are then evaluated, a Groth16 proof is generated and verified before access is granted, and the audit evidence is recorded. Beyond the access decision shown in Figure 4.2, the prototype continues through patient-initiated revocation and the corresponding on-chain revoke transaction, after which the auditor reviews the record and the verification tool performs an independent verification. If the required threshold is not satisfied, the consent remains pending, and any access request made against it is denied. This prevents a single participant from unilaterally establishing authorisation when the consent policy requires collective approval. When the authorisation threshold is satisfied, the requested access is evaluated against the purpose and data-scope constraints defined in the consent object. This step addresses a limitation of identity-based and approval-based access control: a legitimate participant may still request data that fall outside the scope of the patient's consent. For example, if a consent authorises access to observations and medications, a request for observations, medications, and procedures should be rejected because the request exceeds the authorised data scope. Similarly, the purpose must be a supported healthcare use. The full design also requires the requested purpose to match the purpose recorded in the consent, which the prototype does not yet compare, as Chapter 8 explains. Consequently, a valid identity and sufficient multi-party approval are necessary but not sufficient conditions for access. Both successful and denied decisions should be recorded because a trustworthy authorisation framework requires accountability not only for data that were released but also for access attempts that were rejected. In the prototype, every denial, including one against a consent that is not ACTIVE, is recorded with its complete decision matrix.

4.5 Overview of Solution for RQ1

RQ1 asks how patient consent can be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints and authorisation evidence. The solution is the trust-centric consent model of RO1, in which consent is no longer a stored record of permission but the object $C = (I, A, P, T, L, E)$ that every access request is evaluated against. I carries the identity of the patient, the doctor and the guardians; A carries the authority requirements, the guardian set G and the threshold N; P carries the purpose and the data scope; T the validity window; L the lifecycle state; and E the evidence of every decision taken on the consent.

The consent object is created through Algorithm 1. The patient selects the doctor, names the guardians, chooses the data modules, states the purpose and sets the start and expiry dates. The system validates each field, assigns a unique consent identifier, sets the state to PENDING_SIGNATURE, sets N to the number of guardians, persists the object and records the creation event in the audit ledger. From that point the consent can be

evaluated, not merely looked up. The model, the algorithm and its realisation in the HALAH prototype are presented in Chapter 5, together with the research architecture that carries it.

4.6 Overview of Solution for RQ2

RQ2 asks how decentralised identities and verifiable credentials can establish trustworthy participants while separating identity authentication from authorisation authority. The solution is the identity and authority verification mechanism of RO2. Every participant holds a decentralised identifier, and every participant who takes part in a decision holds a verifiable credential issued by a trusted issuer that states their role. When a guardian approves or a doctor requests data, the framework checks the identifier and then the credential: the signature must verify, the issuer must be in the registry of trusted issuers, the subject of the credential must be the identifier presented, the current time must lie inside the validity period, and the role must be the one the step requires. A doctor must also be the doctor named in the consent.

The result is the predicate VI. A valid identity with no credential, or with a credential of the wrong role, fails VI and is refused before any other check. This is what separates who the participant is from what the participant may do. The verification model, Algorithm 2 and its realisation are presented in Chapter 6.

4.7 Overview of Solution for RQ3

RQ3 asks how multiple independently verified participants can jointly establish a trustworthy consent decision without allowing a single participant to authorise access on their own. The solution is the multi-party authorisation mechanism of RO3. The patient fixes the guardian set G and the threshold N when the consent is created. Each guardian signs an approval over the consent identifier and their own identifier, so an approval cannot be moved to another consent. Only approvals from distinct members of G whose credentials verify enter the verified approving set Av; an approval from a signer outside G, or a second approval from the same guardian, does not advance the count.

The consent stays pending, and releases no data, until |Av| reaches N. In the prototype every listed guardian must approve, so N equals |G|. Once the threshold is reached the consent becomes active and a token is recorded as evidence, and the approvals are checked again, as VA, at every later request. The mechanism, Algorithm 3 and its realisation are presented in Chapter 7.

4.8 Overview of Solution for RQ4

RQ4 asks how policy, purpose and data-scope constraints can be incorporated into the authorisation decision so that valid identities and sufficient approvals cannot be used to obtain data outside what the patient allowed. The solution is the policy- and context-aware access control of RO4. The consent carries the purpose and the set of data modules the patient authorised. When a doctor requests data, the predicate VP checks that the purpose is a supported healthcare use and that the requested modules form a non-empty subset of the authorised modules. A request for observations, medications and procedures against a consent that allows observations and medications is refused, although the requester is the right doctor and the guardians have approved.

VP is therefore the condition that makes identity and approval necessary but not sufficient. The policy model, Algorithm 4 and its realisation are presented in Chapter 8.

4.9 Overview of Solution for RQ5

RQ5 asks how temporal validity and lifecycle controls can ensure that an authorisation remains valid only within its permitted time interval and lifecycle state. The solution is the temporal and lifecycle trust of RO5. The consent carries a start time and an expiry time, and the predicate VT checks at every request that the request time lies between them. The consent also has an explicit lifecycle: it is pending until the guardians have approved, active while it can release data, and expired or revoked afterwards. The patient can revoke an active consent at any time. The predicate VL checks at every request that the state is active, so a consent that has expired or been revoked cannot be used, whatever approvals it once held.

Because VT and VL are evaluated at the time of each request rather than once at registration, a change in the consent takes effect on the next request. The lifecycle model, Algorithm 5 and its realisation are presented in Chapter 9.

4.10 Overview of Solution for RQ6

RQ6 asks how the security properties of the authorisation mechanism can be formally defined and empirically evaluated to show that the implemented framework enforces authorised and unauthorised decisions correctly. The solution of RO6 has two parts that complement each other. The formal part defines the security properties of the integrated decision, authorisation integrity, threshold authorisation security and lifecycle safety, and states the assumptions under which they are analysed. The empirical part evaluates the HALAH prototype through scenarios in which the expected and the observed decisions are compared, and through attack scenarios in which each trust condition is deliberately bypassed. Algorithm 6 defines this validation procedure, and Chapter 10 presents the formal properties, the prototype, the scenarios, the measured results and the attack scenarios.

4.10.1 Testing and Verification of the Solution

The prototype is tested at three levels. Live scenarios run the whole workflow through the web interface: a consent is created, each guardian approves, the authorised doctor is allowed, a request that does not satisfy the conditions of the consent is refused, and a request after revocation is refused. Automated tests, 46 in all, check each predicate on its own and together, including twelve attack scenarios, A1 to A12, in which a signer outside G, a replayed signature, a duplicate approval, an over-scope or empty request, a request outside the validity window, a request after revocation, a tampered proof and a forged credential are each refused. The processing time of each check is measured so that the cost of the decision is known. Every decision, allowed or refused, is written to the audit ledger with the result of the five predicates, and the ledger is the evidence used in Chapter 10.

4.11 Conclusion

This chapter presented the research methodology and an overview of the solution. The research follows Design Science Research: the systematic review produced the proposal, the research questions and objectives and the consent model formed the tentative design, the architecture, the algorithms and the HALAH prototype are the artefact, the scenarios, tests, attack scenarios and measured times are the performance measures, and the contributions and remaining work are the result. The solution was then shown as one workflow, from the creation of a consent to the recording of an access decision, and summarised for each research question: an evaluable consent object for RQ1, identity and authority verification for RQ2, multi-party authorisation for RQ3, policy and scope enforcement for RQ4, temporal and lifecycle control for RQ5, and formal and empirical

assurance for RQ6. The next chapter presents the research architecture and the trust-centric consent model in full.